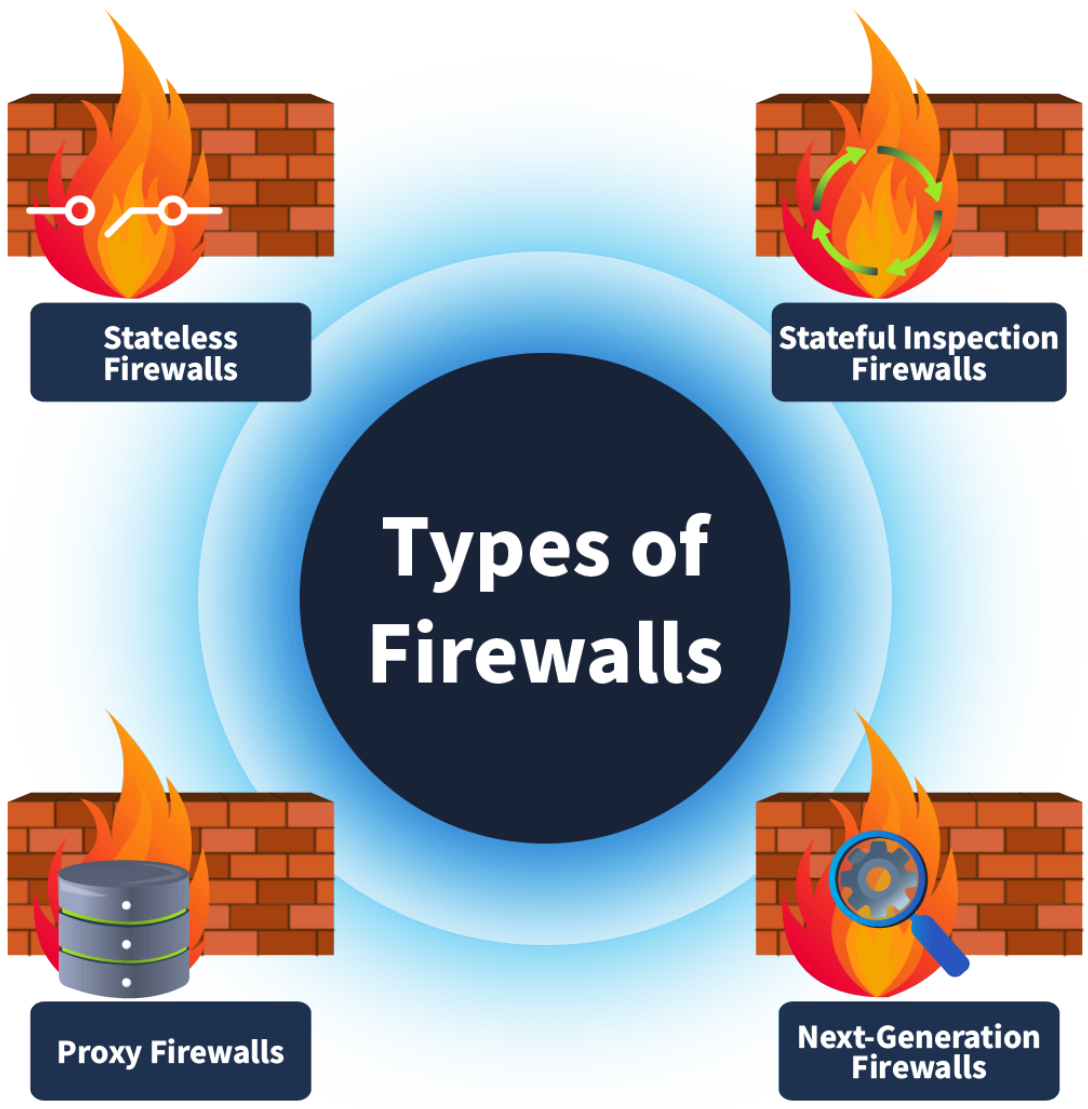
FIREWALL FUNDAMENTALS

A lot of incoming and outgoing traffic flows daily between our digital devices and the Internet they are connected to. What if somebody sneaks in between this massive traffic without getting caught? We would also need a security guard for our digital devices then, who can check the data coming in and going out of them. This security guard is what we call a **firewall**. A firewall is designed to inspect a network's or digital device's incoming and outgoing traffic. The goal is the same as for the security guard sitting outside a building: not letting any unauthorized visitor enter a system or a network. You instruct the firewall by giving it rules to check against all the traffic. Anything that comes in or goes out of your device or network would face the firewall first. The firewall will allow or deny that traffic based on its maintained rules. Most firewalls today go beyond rule-based filtering and offer extra functionalities to protect your device or network from the outside world. We will discuss all these firewalls and perform practical lab demonstrations on a few.

Firewall deployment became common in networks after organizations discovered their ability to filter harmful traffic from their systems and networks. Several different types of firewalls were introduced afterward, each serving a unique purpose. It's also important to note that different types of firewalls work on different OSI model layers. Firewalls are categorized into many types.

Let's examine a few of the most common types of firewalls and their roles in the OSI model.



Stateless Firewall

This type of firewall operates on layer 3 and layer 4 of the OSI model and works solely by filtering the data based on predetermined rules without taking note of the state of the previous connections. This means it will match every packet with the rules regardless of whether it is part of a legitimate connection. It maintains no information on the state of the previous connections to make decisions for future packets. Due to this, these firewalls can process the packets quickly. However, they cannot apply complex policies to the data based on its relationship with the previous connections. Suppose the firewall denies a few packets from a single source based on its rules. Ideally, it should drop all the future packets from this source because the previous packets could not comply with the firewall's rules. However, the firewall keeps forgetting this, and future packets from this source will be treated as new and matched by its rules again.

Stateful Firewall

Unlike stateless firewalls, this type of firewall goes beyond filtering packets by predetermined rules. It also keeps track of previous connections and stores them in a state table. This adds another layer of security by inspecting the packets based on their history with connections. Stateful firewalls operate at layer 3 and layer 4 of the OSI model. Suppose the firewall accepts a few packets from a source address based on its rules. In that case, it will take note of this connection in its stated table and allow all the future packets for this connection to automatically get allowed without inspecting each of them. Similarly, the stateful firewalls take note of the connections for which they deny a few packets, and based upon this information, they deny all the subsequent packets coming from the same source.

Proxy Firewall

The problem with previous firewalls was their inability to inspect the contents of a packet. Proxy firewalls, or application-level gateways, act as intermediaries between the private network and the Internet and operate on the OSI model's layer 7. They inspect the content of all packets as well. The requests made by users in a network are forwarded by this proxy after inspection and masking them with their own IP address to provide anonymity for the internal IP addresses. Content filtering policies can be applied to these firewalls to allow/deny incoming and outgoing traffic based on their content.

Next-Generation Firewall (NGFW)

This is the most advanced type of firewall that operates from layer 3 to layer 7 of the OSI model, offering deep packet inspection and other functionalities that enhance the security of incoming and outgoing network traffic. It has an intrusion prevention system that blocks malicious activities in real time. It offers heuristic analysis by analyzing the patterns of attacks and blocking them instantly before reaching the network. NGFWs have SSL/TLS decryption capabilities, which inspect the packets after decrypting them and correlate the data with the threat intelligence feeds to make efficient decisions.

The table below lists each firewall's characteristics, which will help you choose the most suitable firewall for different use cases.

Firewalls	Characteristics
Stateless firewalls	- Basic filtering- No track of previous connections- Efficient for high-speed networks
Stateful firewalls	- Recognize traffic by patterns- Complex rules can be applicable- Monitor the network connections
Proxy firewalls	- Inspect the data inside the packets as well- Provides content filtering options- Provides application control- Decrypts and inspects SSL/TLS data packets
Next-generation firewalls	- Provides advanced threat protection- Comes with an intrusion prevention system- Identify anomalies based on heuristic analysis- Decrypts and inspects SSL/TLS data packets

A firewall gives you control over your network's traffic. Although it filters the traffic based on its built-in rules, some customized rules can be defined for various networks. For example, there would be networks that want to deny all the SSH traffic coming into their network. However, your network would have a requirement to allow SSH traffic from a few specific IP addresses. The rules allow you to configure these customized settings for your network's incoming and outgoing traffic.

The basic components of a firewall's rule are described below:

- **Source address:** The machine's IP address that would originate the traffic.
- **Destination address:** The machine's IP address that would receive the data.
- **Port:** The port number for the traffic.
- **Protocol:** The protocol that would be used during the communication.

- **Action:** This defines the action that would be taken upon identifying any traffic of this particular nature.
- **Direction:** This field defines the rule's applicability to incoming or outgoing traffic.

Types of Actions

The component "Action" from a rule indicates the steps to take after a data packet falls under the category of the defined rule. Three main actions that can be applied to a rule are explained below.

Allow

A rule's "Allow" action indicates that the particular traffic defined inside the rule would be permitted.

For example, let's create a rule with an action to allow all the outgoing traffic from our network for port 80 (used for HTTP traffic to the Internet).

Action	Source	Destination	Protocol	Port	Direction
Allow	192.168.1.0/24	Any	TCP	80	Outbound

Deny

A rule's "Deny" action means that the traffic defined inside the rule would be blocked and not permitted. These rules are fundamental for the security team to deny specific traffic coming from malicious IP addresses and create more rules to reduce the threat surface of the network.

For example, let's create a rule with an action to deny all the incoming traffic on port 22 (used for remotely connecting to a machine via SSH) of our critical server.

Action	Source	Destination	Protocol	Port	Direction
Deny	Any	192.168.1.0/24	TCP	22	Inbound

Forward

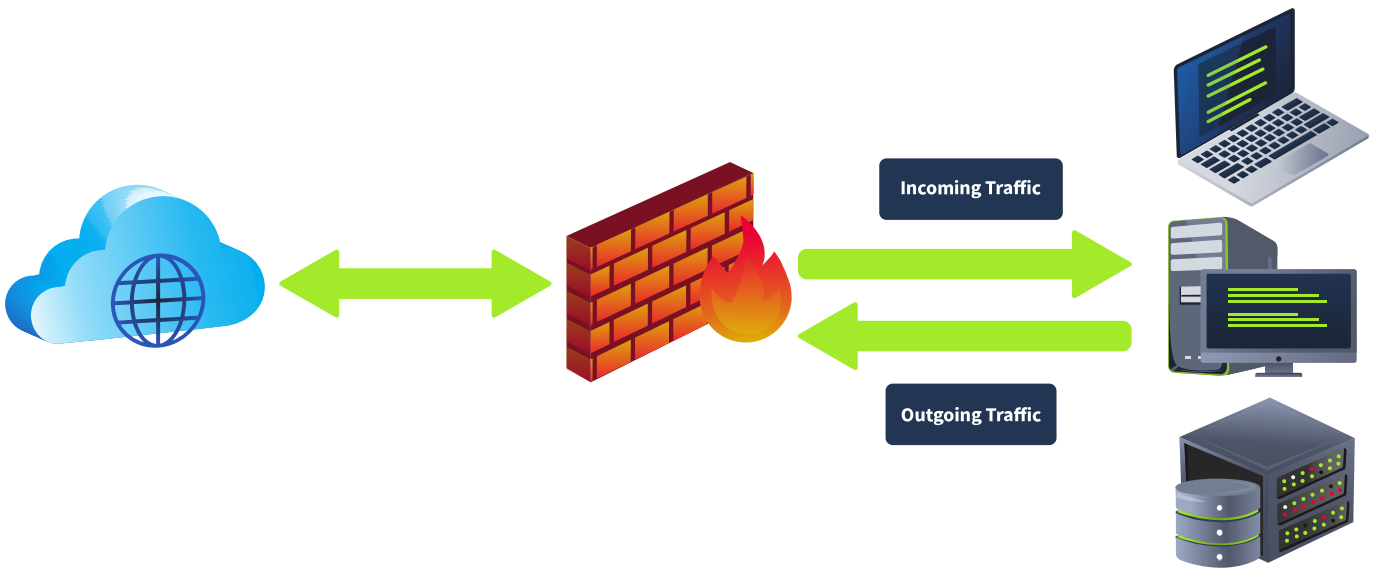
The action "Forward" redirects traffic to a different network segment using the forwarding rules created on the firewalls. This applies to the firewalls that provide routing functionality and act as gateways between different network segments.

For example, let's create a rule with an action to forward all the incoming traffic on port 80 (used for HTTP traffic) to the web server `192.168.1.8`.

Action	Source	Destination	Protocol	Port	Direction
Forward	Any	192.168.1.8	TCP	80	Inbound

Directionality of Rules

Firewalls have different categories of rules, each categorized based on the traffic directionality on which the rules are created. Let's examine each of these directionalities.



Inbound Rules

Rules are categorized as inbound rules when they are meant to be applied to incoming traffic only. For example, you might allow incoming HTTP traffic (port 80) on your web server.

Outbound Rules

These rules are made for outgoing traffic only. For example, blocking all outgoing SMTP traffic (port 25) from all the devices except the mail server.

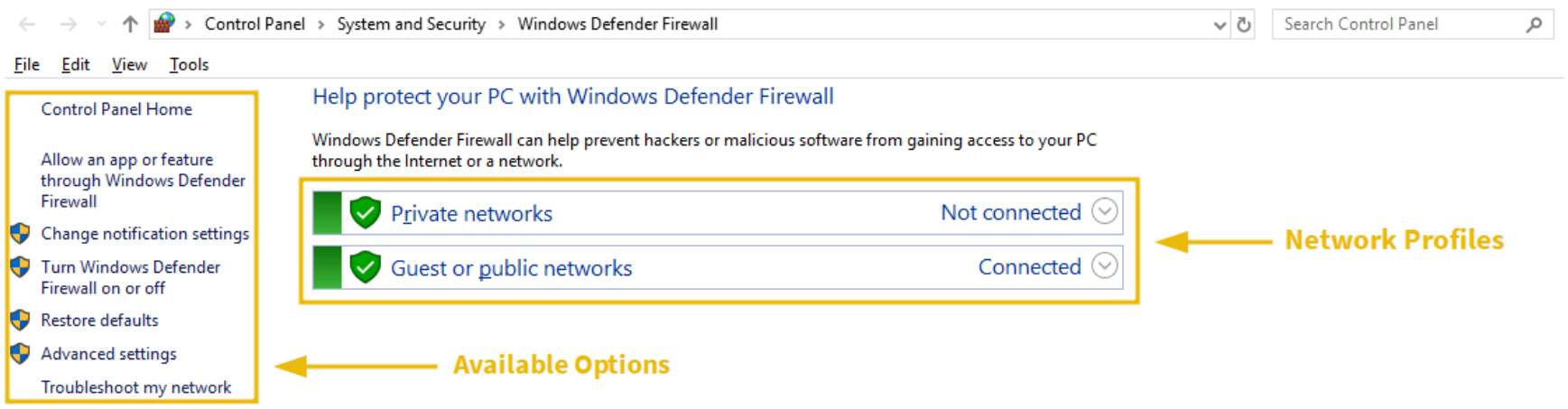
Forward Rules

Forwarding rules are created to forward specific traffic inside the network. For example, a forwarding rule can be created to forward the incoming HTTP (port 80) traffic to the web server located in your network.

Windows Defender Firewall

Windows Defender is a built-in firewall introduced by Microsoft in the Windows OS. This firewall contains all the basic functionality for creating, allowing, or denying specific programs or creating customized rules. This task is designed to cover some of the essential components of the Windows Defender Firewall, which you can utilize to restrict your system's incoming and outgoing network traffic. To open this firewall, you have to open the Windows search and type "Windows Defender Firewall."

The Windows Defender Firewall's home page shows the "Network Profiles" and the available options. This is the main dashboard with all the options for the firewall.

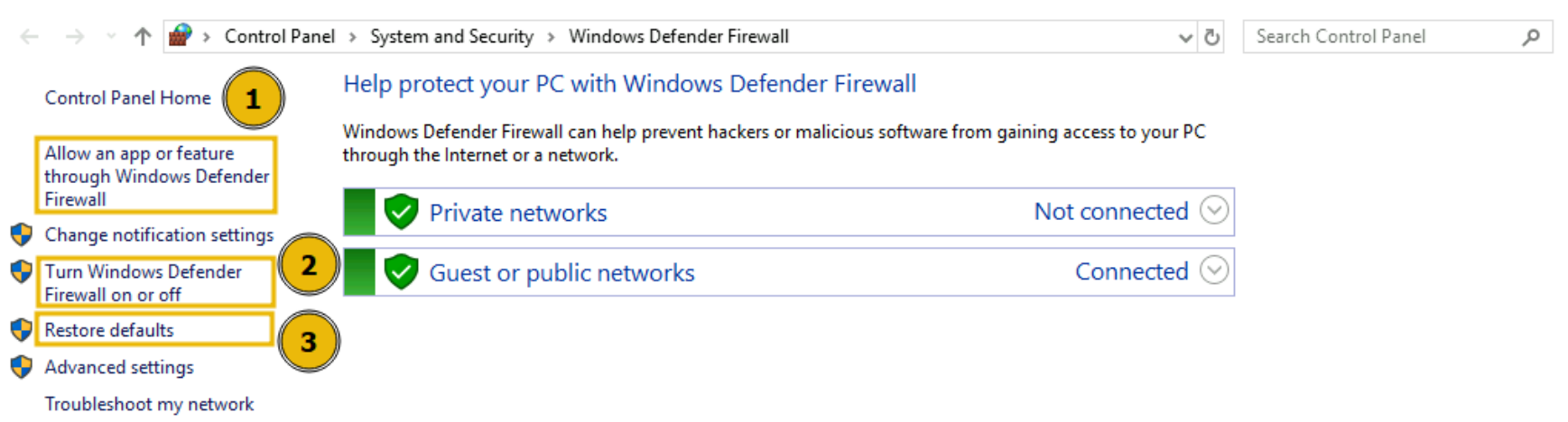


Network Profiles

There are two available network profiles. Windows firewall determines your current network based on Network Location Awareness (NLA) and applies that profile firewall settings for you. We can have different firewall settings for each of them.

1. **Private networks:** This includes the firewall configurations to apply when connected to our home network.
2. **Guest or public networks:** This includes the firewall configurations to apply when connected to a public or untrusted network like coffee shops, restaurants, or similar. For example, when connecting to public networks, you can configure firewall settings to block all incoming network connections and allow only some outgoing connections that are essential for you. These settings will apply to the public network profile and will not be implemented when you are in your private home network.

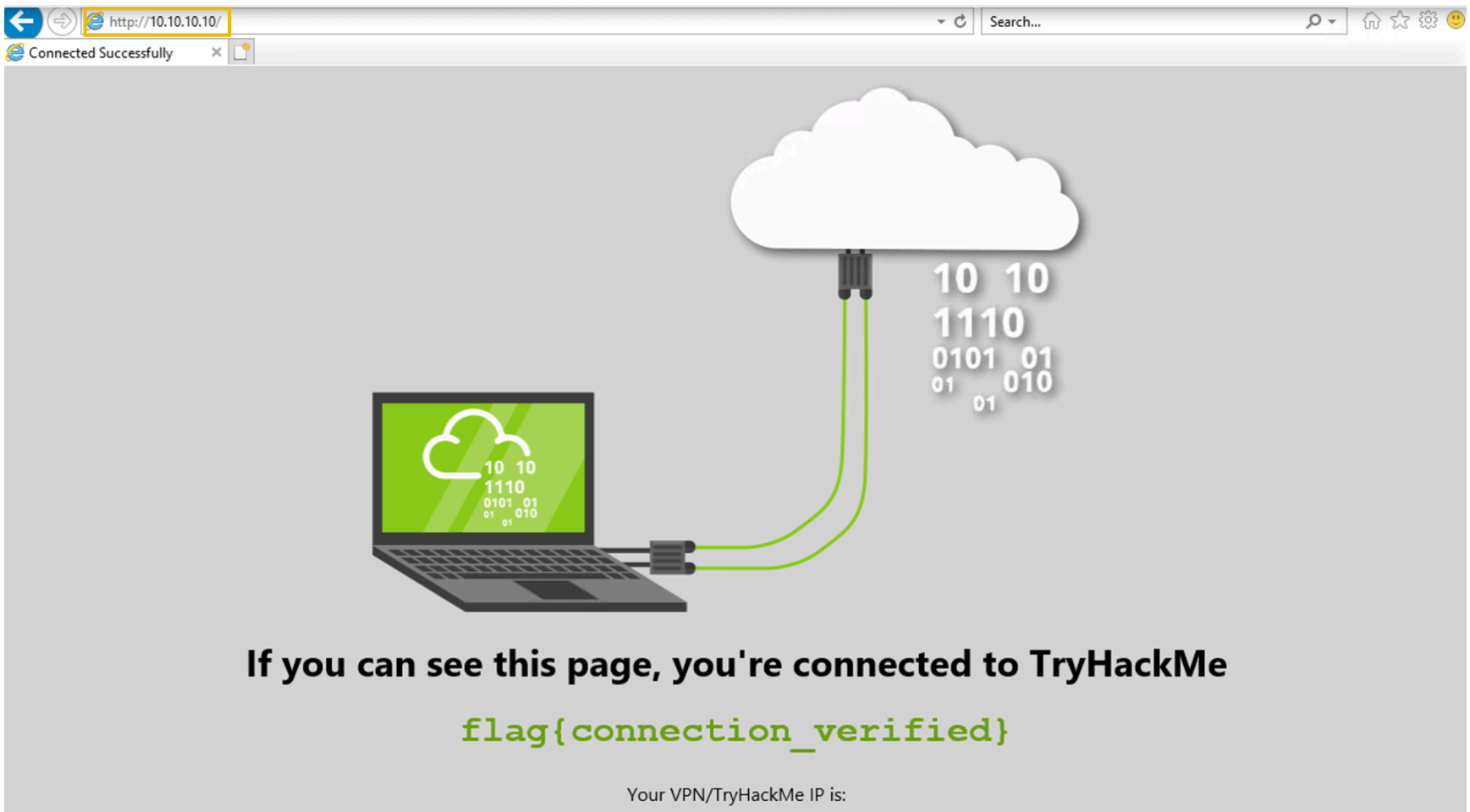
To allow/disallow any application in any of your network profiles, click on the option (highlighted as 1 in the screenshot). This will take you to the page listing all the apps and features installed in your system. You can checkmark the ones you want to allow in any of your network profiles or uncheck those if not needed. Windows Defender Firewall is turned on by default. However, if you want to turn it on/off, you can click on the option (highlighted as 2 in the screenshot). This will take you to the settings for both of your network profiles. Rather than completely turning it off, which Microsoft doesn't recommend, you can also block all incoming connections. You can also click on "Restore Defaults" (highlighted as 3 in the screenshot) from the main dashboard anytime to restore all the firewall's default settings.



Custom Rules

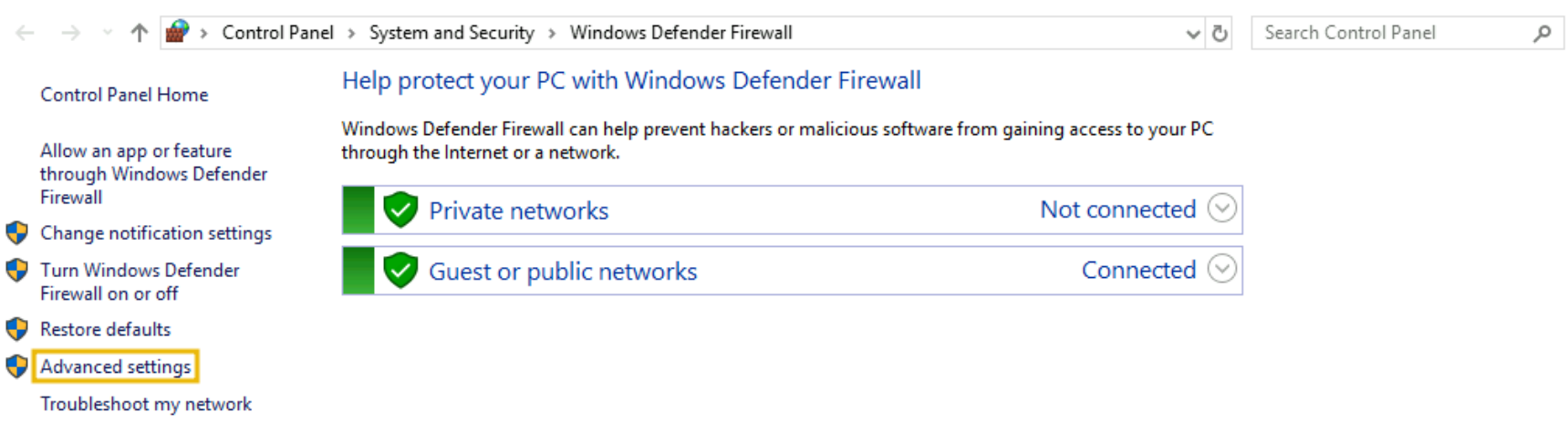
Windows Defender Firewall also allows you to create custom rules for your network to allow/disallow specific traffic as needed. Let's create a custom rule to block all outgoing traffic on HTTP (port 80) or HTTPS (port 443). After creating this rule, we will be unable to browse any website on the Internet as the websites are working on port 80 or 443, which we will be blocking.

Before creating this rule, let's test if we are able to visit a website. For testing, let's visit `http://10.10.10.10/`. As shown in the screenshot below, we are able to visit this website.

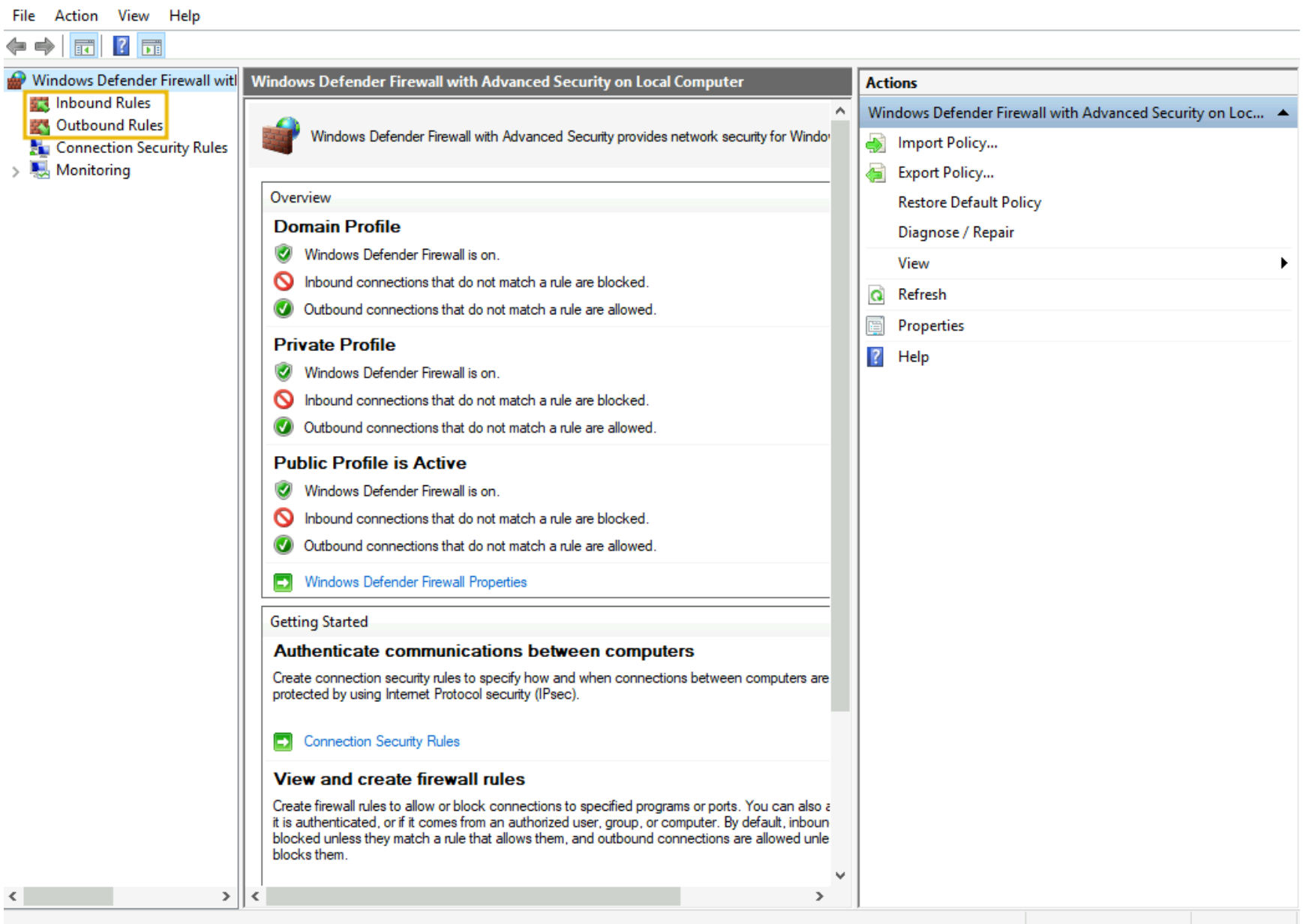


To create a custom rule, choose "Advanced Settings" from the available options in the main dashboard. This will open a new tab where you can create your own rules.

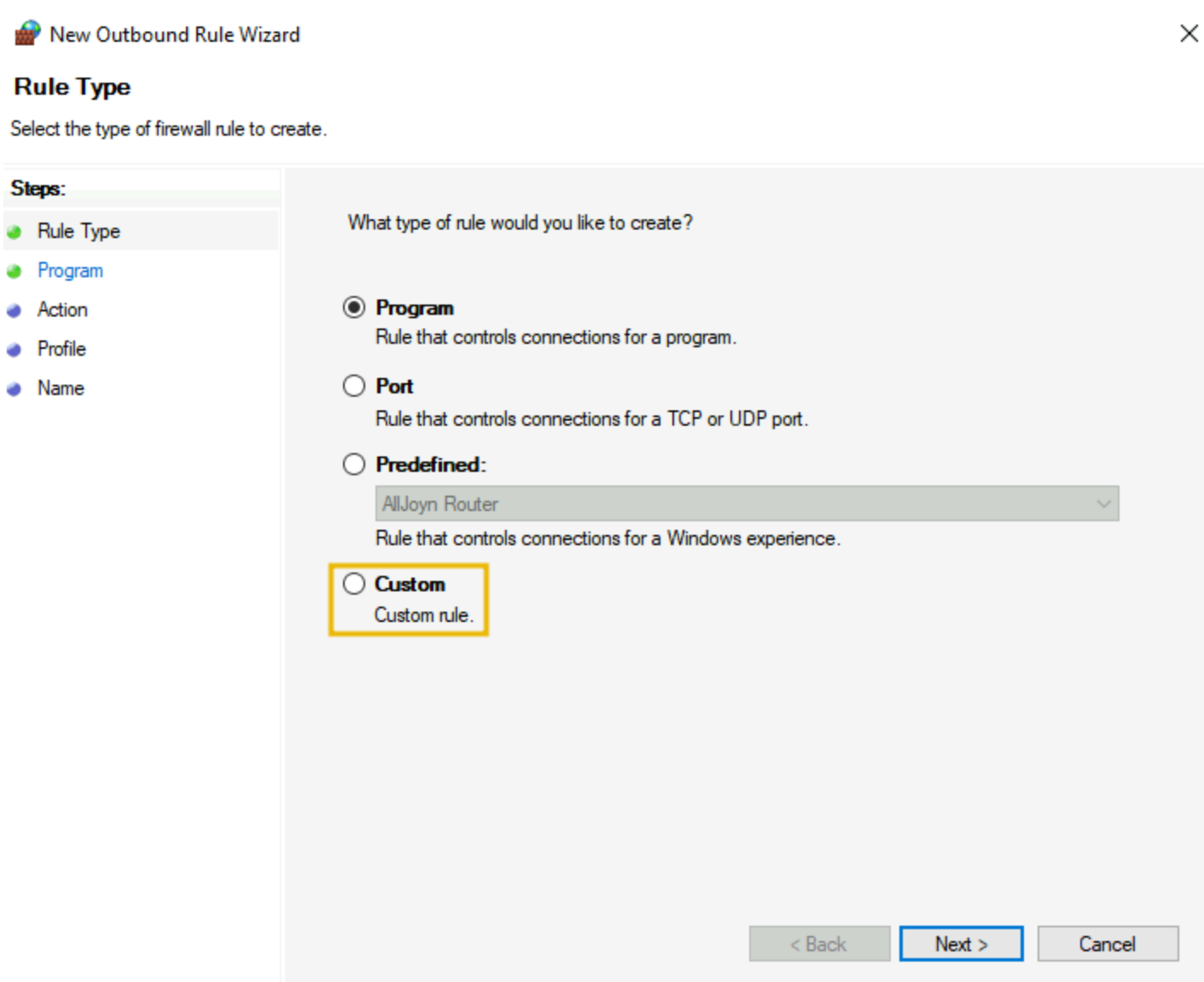
Note: The rule created below is already available inside the attached VM. If you want to test it, you can create it on your Windows host machine or any other machine.



You can see the available options to create inbound and outbound rules.

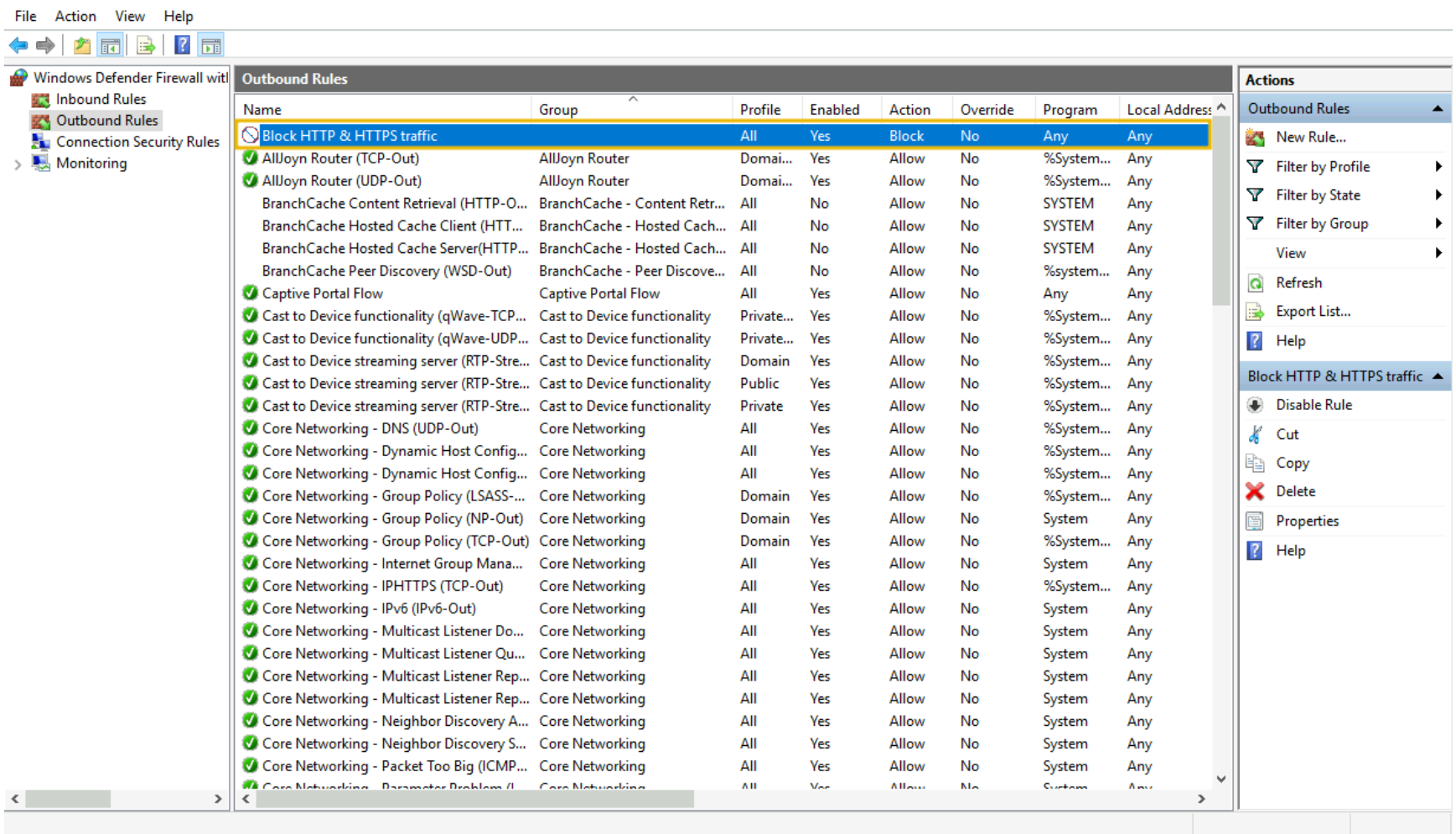


Let's create an outbound rule to block all our outgoing HTTP and HTTPS traffic. For this, click on the **Outbound Rules** option on the left side, then click on **New Rule** on the right side. It will open the rule wizard.In the first step, select the **Custom** option and press **Next**.

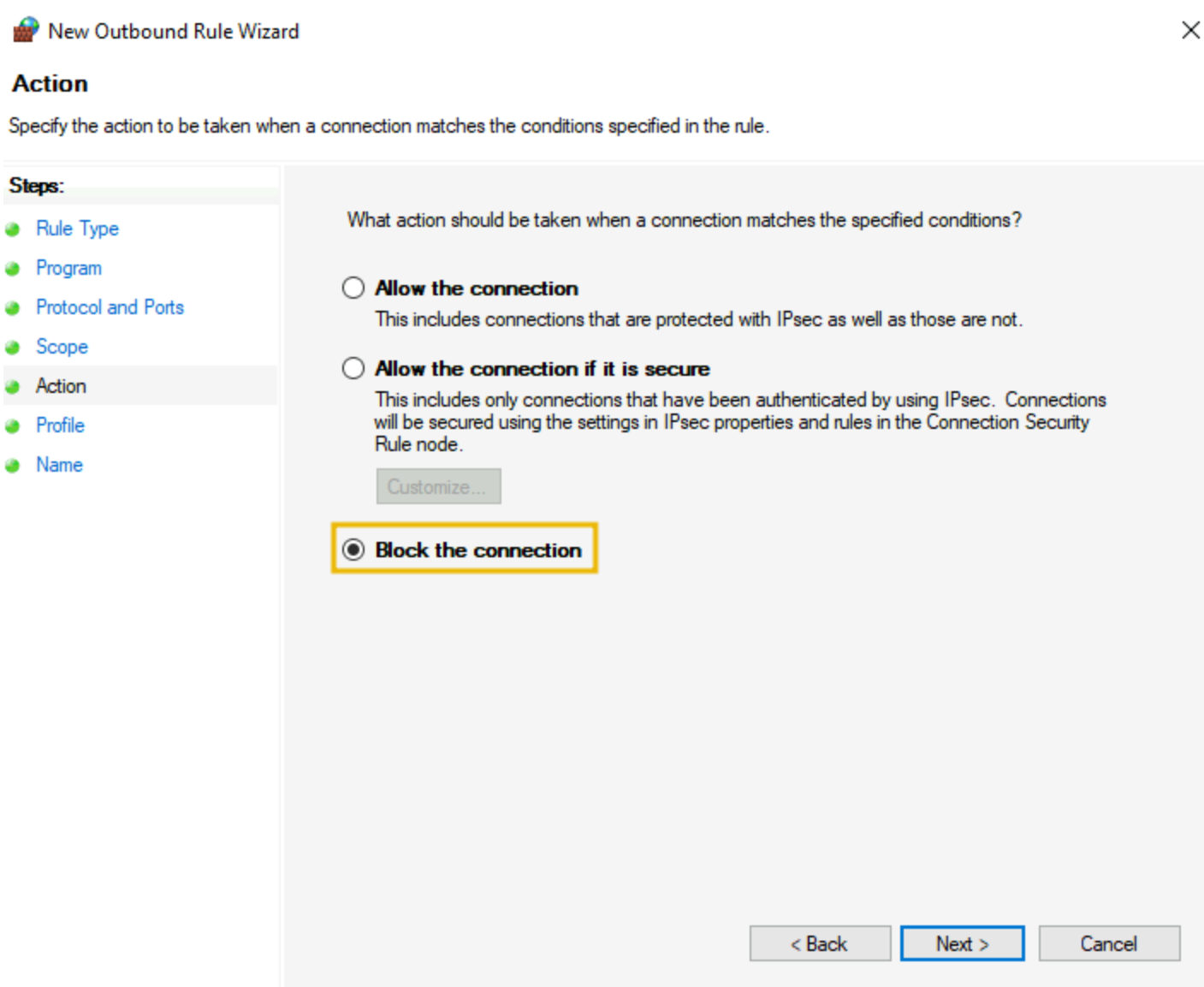


In the second step, select **All programs** from the next option and press **Next**. It will ask you to select the protocol type in the third step. Select the **Protocol type** as "TCP", keep the **Local port** as it is, and change the **Remote port** to "Specific ports" from the dropdown. Write the port numbers in the field below (in our case, 80,443). Now, click on **Next**.

Note: Separate the port numbers by commas, and please don't leave spaces between them.

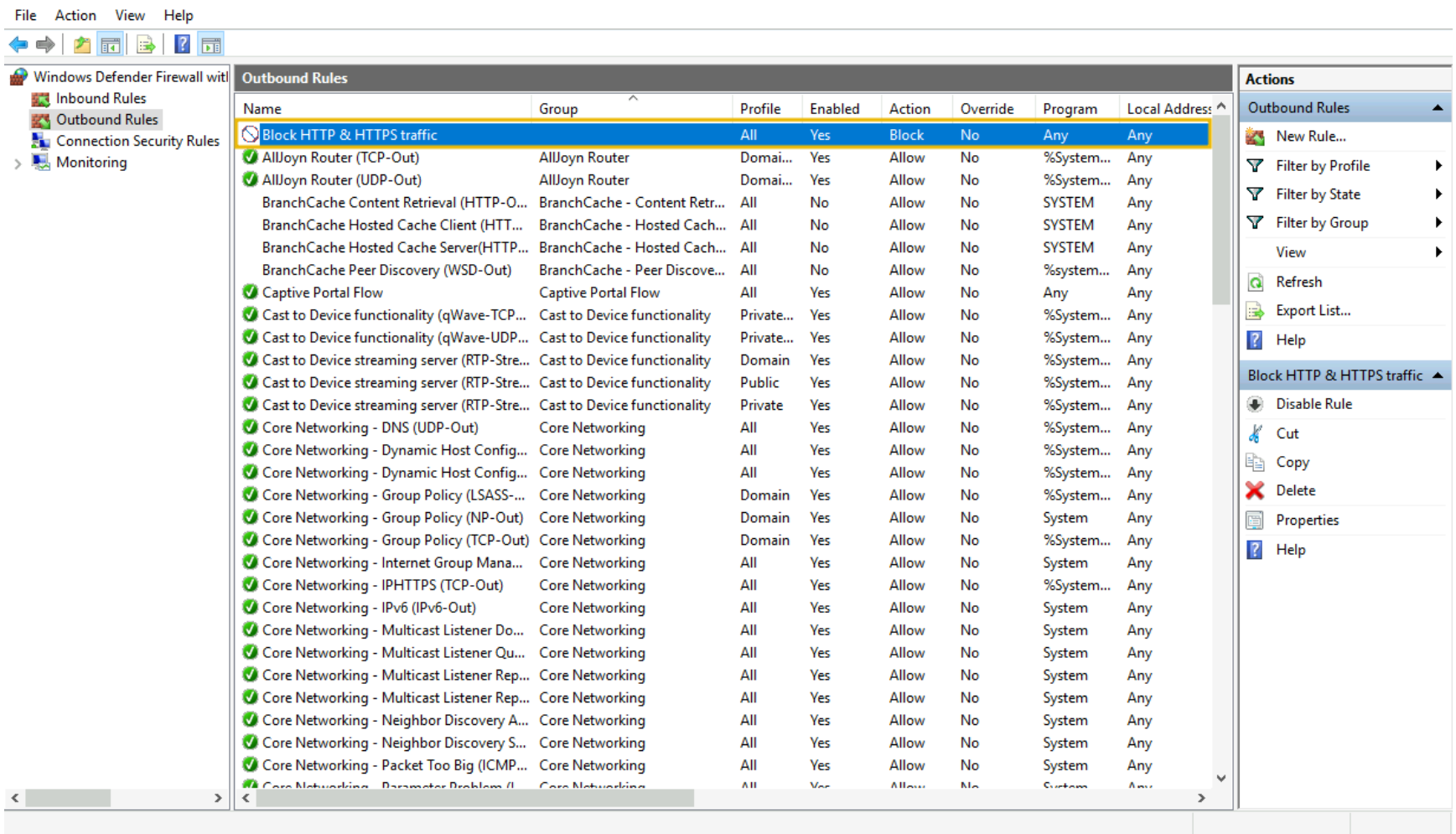


In the **Scope** tab, keep the local and remote IP addresses as they are and press the **Next** button. In the **Action** tab, enable the **Block the connection** option and press **Next**.

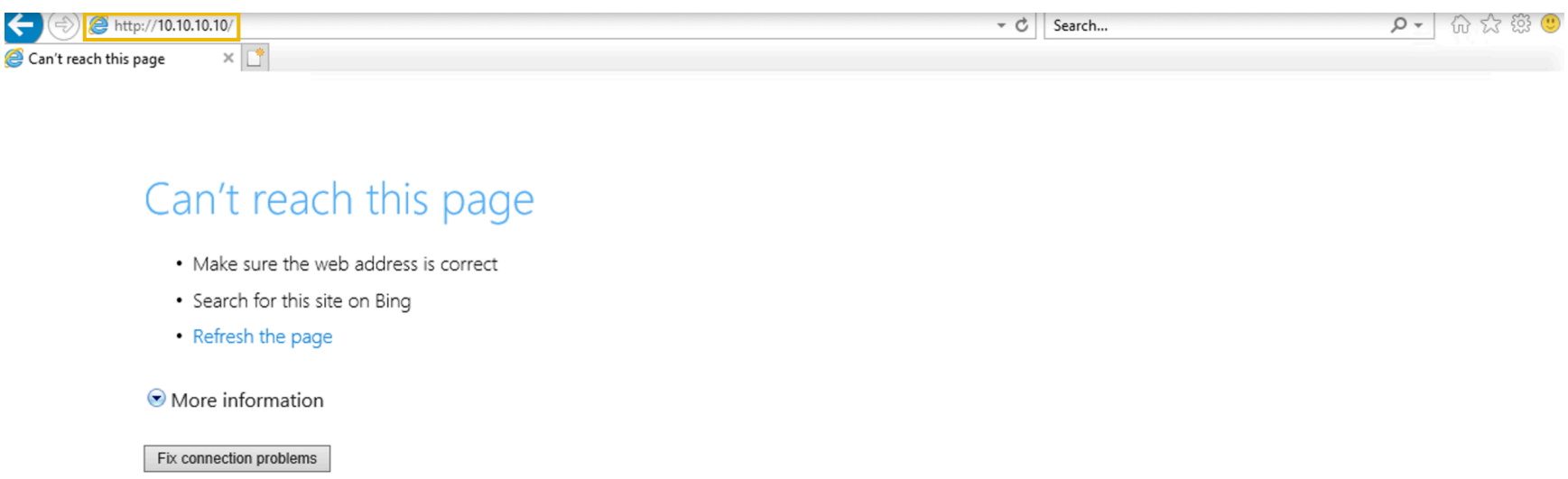


In the **Profile** tab, we keep all the network profiles check-marked. Lastly, the final phase is to give your rule a name and an optional description and press the **Finish** button.

We can see our rule is there in the available outbound rules.



Now, let's test our rule by browsing to `http://10.10.10.10/`. We get an error message saying we cannot reach this page, meaning the rule works.



The security team noticed suspicious incoming and outgoing traffic on their critical Windows system. They created rules on their Windows Defender Firewall to block some of their specific network traffic.

LINUX iptables firewall

In the previous task, we discussed the built-in firewall available in the Windows OS. What if you are a Linux user? You still need control over your network traffic. Linux also offers the functionality of a built-in firewall. We have multiple firewall options available here. Let's briefly review most of them and explore one of them in detail.

Netfilter

Netfilter is the framework inside the Linux OS with core firewall functionalities, including packet filtering, NAT, and connection tracking. This framework serves as the foundation for various firewall utilities available in Linux to control network traffic. Some common firewall utilities that utilize this framework are listed below:

- **iptables:** This is the most widely used utility in many Linux distributions. It uses the Netfilter framework that provides various functionalities to control network traffic.
- **nftables:** It is a successor to the "iptables" utility, with enhanced packet filtering and NAT capabilities. It is also based on the Netfilter framework.
- **firewalld:** This utility also operates on the Netfilter framework and has predefined rule sets. It works differently from the others and comes with different pre-built network zone configurations.

ufw

ufw (Uncomplicated Firewall), as the name says, eliminates the complications of making rules in a complex syntax in “iptables”(or its successor) by giving you an easier interface. It is more beginner-friendly. Basically, whatever rules you need in “iptables”, you can define them with some easy commands via ufw, which would then be configuring your desired rules in “iptables”. Let’s have a look at some basic ufw commands down below.

To check the status of the firewall, you could use the command below:

Check status

```
user@ubuntu:~$ sudo ufw statusStatus: inactive
```

If it appears inactive, you can enable it using the following command:

Enablefirewall

```
user@ubuntu:~$ sudo ufw enableFirewall is active and enabled on system startup
```

To turn off the firewall, type “disable” instead of “enable” in the above command.

Below is a rule created to allow all the outgoing connections from a Linux machine. The `default` in the command means that we are defining this policy as a default policy allowing all the outgoing traffic unless we define an outgoing traffic restriction on any specific application in a separate rule. You can also make a rule to allow/deny traffic coming into your machine by replacing `outgoing` with `incoming` in the following command:

Allow all outgoing traffic

```
user@ubuntu:~$ sudo ufw default allow outgoingDefault outgoing policy changed to 'allo
w'
(be sure to update your rules accordingly)
```

You can deny incoming traffic at any port in your system. Let's say that we want to block incoming SSH traffic. We can achieve this with the command `ufw deny 22/tcp`. As you can see, we first specified the action, `deny` in this case; furthermore, we specified the port and the transport protocol, which is TCP port 22, or simply `22/tcp`.

Deny incomingSSHtraffic

```
user@ubuntu:~$ sudo ufw deny 22/tcpRule added
Rule added (v6)
```

To list down all the active rules in a numbered order, you can use the following command:

List all rules

```
user@ubuntu:~$ sudo ufw status numbered     To                         Action      Fro
m
     --                          ------      ----
[ 1] 22/tcp                      DENY IN     Anywhere
[ 2] 22/tcp (v6)                 DENY IN     Anywhere (v6)
```

To delete any rule, execute the following command with the rule number to delete:

Delete a rule

```
user@ubuntu:~$ sudo ufw delete 2Deleting:
 deny 22/tcp
Proceed with operation (y|n)? y
Rule deleted (v6)
```

These different utilities can be used to manage Netfilter. Choosing the right utility for the Linux OS depends on multiple factors, such as familiarity with the OS and your requirements. You can test your knowledge of Linux firewalls by creating some rules defined in this task and testing them to ensure they are working as expected.